

ADR 0018 — Stale, tampered or expired plans never execute

- **Status:** Accepted
- **Date:** 2026-07-24
- **Milestone / issue:** M1.06d — Enforce plan staleness, generation checks, and expiry rejection (#145, child of #59)
- **Supersedes / superseded by:** — (makes ADR 0015's generation/hash/expiry fields and ADR 0016's validate seam load-bearing)

Context

Since #143 every write action builds a `Plan` carrying a repository generation, an operation hash and an expiry — but `validate` only checked hash and expiry structurally, generation was informational, and preconditions were purely descriptive. The gap between "plan was built" and "plan is executed" (today microseconds, after the client review roundtrip a whole user think-time) had no enforcement: a repository that moved between observation and mutation would still be mutated on stale assumptions.

Decision

`plan_and_execute` gains an execution-time staleness gate between `validate` and `execute` — `enforce_fresh`, running immediately before the executor:

1. **Generation equality.** The generation token is recomputed from the live repository and must equal the plan's. Its inputs now include the worktree/ index status (`git status --porcelain=v2`) beside HEAD and every ref, so uncommitted-work drift also counts as the repository moving. The token stays opaque and equality-compared, so deepening inputs was not a wire change (ADR 0015's contract).
2. **Live precondition re-verification.** Every precondition the build observed to hold (`Observed::held_at_build`) is re-checked against the live repository: refs still where the plan says, checkout state, clean worktree, remote configured, seed recorded. A precondition that already failed at build time is deliberately not enforced here — it flows to the executor's legacy guard so refusal texts stay exactly what they were (#143's no-behavior-change promise holds on non-race paths).
3. **Hash and expiry** remain in `validate`: a plan whose operation no longer matches its declared SHA-256 is refused (tamper detection), and a plan past its 300 s TTL is refused with a client-facing reason.

Every refusal is a 409 with a plain-language reason ("The repository changed while this plan was pending — refresh and try again."). Drift always fails closed; nothing proceeds on stale assumptions.

Alternatives considered

- **Enforce all preconditions, not just build-held ones.** Simpler, but changes refusal texts on the normal (non-race) failure paths that the executors already guard with operation-specific wording — a silent behavior change #143 promised not to make.
- **Serialize writes behind a lock instead.** Prevents in-process races only; the repository is also mutated by terminals and other tools. Equality checks against the live repo catch every writer.
- **Trust the executor guards alone.** They compare against build-time observations — exactly the TOCTOU window this closes.

Consequences

- Each write costs two extra read-only observations (status at build, full re-observation at execute). User-initiated writes; negligible.
- The client review roundtrip (M2+) inherits a gate that already works: the same checks simply run across a longer window.
- Tests pin each rejection independently (`planner::tests`): generation move (worktree-only and ref drift), tampered hash, expired plan, a precondition race the generation check cannot see (remote removed), and the legacy-path passthrough.